

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC FPT**

**KIẾN TRÚC NHẬN THỨC HAI TẦNG CHO PHÁT HIỆN
VÀ PHẢN HỒI MỐI ĐE DỌA TỰ ĐỘNG SỬ DỤNG AI
TÁC TỬ (AGENTIC AI)**

thực hiện bởi

Nguyễn Đức Bình

Luận văn được nộp để đáp ứng yêu cầu
của học vị Thạc sĩ Kỹ thuật Phần mềm

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC FPT**

**KIẾN TRÚC NHẬN THỨC HAI TẦNG CHO PHÁT HIỆN
VÀ PHẢN HỒI MỐI ĐE DỌA TỰ ĐỘNG SỬ DỤNG AI
TÁC TỬ (AGENTIC AI)**

thực hiện bởi

Nguyễn Đức Bình

Luận văn được nộp để đáp ứng yêu cầu
của học vị Thạc sĩ Kỹ thuật Phần mềm

Giảng viên hướng dẫn:
TS. Bùi Văn Hiếu
TS. Đặng Văn Hiếu

Tóm tắt

Trong bối cảnh an ninh mạng hiện đại, các Trung tâm Điều hành An ninh mạng (SOC) luôn bị quá tải bởi số lượng cảnh báo khổng lồ, dẫn đến hội chứng "bội thực cảnh báo" và nguy cơ bỏ sót các Cuộc tấn công có chủ đích (APT) nghiêm trọng. Để giải quyết những hạn chế cố hữu của các hệ thống dựa trên luật tính truyền thống và nút thắt về độ trễ khi xử lý trực tiếp log mạng qua Mô hình Ngôn ngữ Lớn (LLM), luận văn này giới thiệu SENTINEL: Kiến trúc nhận thức hai tầng cho phát hiện và phản hồi mối đe dọa tự động. Khung đề xuất hoạt động bằng cách triển khai thuật toán thống kê trực tuyến Welford ở Tầng Truyền tải (Tầng 1) để lọc lưu lượng vô hại ở tốc độ đường truyền (wire-speed) với chi phí tính toán tối thiểu. Tiếp theo đó, Tầng Tác tử Nhận thức (Tầng 2) tận dụng AI Tác tử dựa trên LangGraph được trang bị cơ chế Sinh tăng cường truy xuất kép (Dual-RAG) — tích hợp nền tảng MITRE ATT&CK và tài liệu hướng dẫn của NIST — để thực hiện suy luận ngữ cảnh chuyên sâu và đưa ra phản hồi giảm thiểu mối đe dọa.

Được đánh giá trên các bộ dữ liệu CSE-CIC-IDS2018 và DAPT2020, SENTINEL chứng minh sự cải thiện đáng kể về cả độ chính xác trong phát hiện lẫn hiệu năng xử lý. Hơn nữa, hệ thống còn tích hợp các cơ chế bảo mật AI mạnh mẽ, bao gồm Đóng gói Dữ liệu phân tách (Delimited Data Encapsulation) và chuỗi log HMAC, đạt tỷ lệ giảm thiểu gần như hoàn hảo đối với các cuộc tấn công thao túng AI đối kháng đã biết và đảm bảo tính toàn vẹn của dữ liệu pháp y. Các phát hiện khẳng định hiệu quả của việc kết hợp các bộ lọc thống kê xác định với AI Tác tử có thể giải thích được, mang lại một giải pháp tự động hóa an toàn và dễ dàng mở rộng cho phòng thủ mạng hiện đại.

Lời cảm ơn

Tôi xin gửi lời biết ơn chân thành và sâu sắc nhất tới hai vị giảng viên hướng dẫn của tôi, TS. Bùi Văn Hiếu và TS. Đặng Văn Hiếu. Sự định hướng khoa học chuẩn xác, những phản hồi chuyên môn sắc bén cùng sự tận tâm và kiên nhẫn chỉ dạy của các thầy trong suốt chặng đường thực hiện đề tài chính là bệ đỡ vững chắc giúp tôi hoàn thành nghiên cứu này một cách trọn vẹn nhất.

Tôi cũng xin bày tỏ lòng biết ơn sâu sắc tới các giảng viên và cán bộ nhân viên tại Trường Đại học FPT, đặc biệt là Ban đào tạo chương trình Thạc sĩ Kỹ thuật Phần mềm (MSE), những người đã trang bị cho tôi nền tảng tri thức học thuật quý báu, tạo dựng một môi trường nghiên cứu chuyên nghiệp, hiện đại và hỗ trợ tối đa mọi điều kiện thuận lợi cho học viên trong suốt quá trình học tập.

Đồng thời, tôi xin gửi lời cảm ơn tới Ban lãnh đạo và các đồng nghiệp tại FPT Software, nơi tôi đang công tác. Sự tạo điều kiện về mặt thời gian, môi trường làm việc thực tế và những chia sẻ chuyên môn từ các đồng nghiệp đã giúp tôi có thêm nhiều động lực để hoàn thành tốt cả công việc tại cơ quan lẫn nhiệm vụ học tập nghiên cứu.

Cuối cùng và quan trọng nhất, tôi xin dành lời tri ân đặc biệt tới gia đình yêu thương của mình, đặc biệt là người vợ hiền cùng con nhỏ. Sự hy sinh thầm lặng, lòng kiên nhẫn, thấu hiểu và động viên tinh thần không ngừng nghỉ của gia đình trong những khoảng thời gian tôi bận rộn với các đợt thực nghiệm kéo dài chính là điểm tựa lớn nhất giúp tôi vững bước trên hành trình chinh phục học vị Thạc sĩ.

Danh sách hình vẽ

2.1	Nút thắt nhận thức ở con người trong các hệ thống SOC truyền thống khi đối mặt với khối lượng cảnh báo vượt quá khả năng xử lý.	17
2.2	Quy trình phân tích sự cố của hệ thống AI Tác tử dựa trên mô hình Đồ thị Trạng thái (FSM).	19
2.3	Cơ chế hoạt động của cuộc tấn công ”Log-Substrate Prompt Injection”: Kẻ tấn công nhúng lệnh thao túng vào luồng log để lừa gạt mô hình LLM. . .	21

Danh sách bảng

1.1	Ánh xạ giữa Câu hỏi Nghiên cứu và các Thành phần Hệ thống.	12
2.1	Tóm tắt các Lỗi hỏng Nhận thức của LLM và Biện pháp Giảm thiểu trong SENTINEL.	22

Danh mục các từ viết tắt

Từ viết tắt	Định nghĩa đầy đủ
AI	Artificial Intelligence (Trí tuệ nhân tạo)
APT	Advanced Persistent Threat (Mối đe dọa thường trực nâng cao)
C2	Command and Control (Chỉ huy và điều khiển)
CIDR	Classless Inter-Domain Routing (Định tuyến liên miền không phân lớp)
CNN	Convolutional Neural Network (Mạng nơ-ron tích chập)
CVE	Common Vulnerabilities and Exposures (Danh sách lỗ hổng bảo mật phổ biến)
CTI	Cyber Threat Intelligence (Tinh báo mối đe dọa mạng)
DAPT	Dynamic/Delayed Advanced Persistent Threat (Tấn công APT động/trễ)
DDoS	Distributed Denial of Service (Từ chối dịch vụ phân tán)
DL	Deep Learning (Học sâu)
DoS	Denial of Service (Từ chối dịch vụ)
EDR	Endpoint Detection and Response (Phát hiện và phản hồi điểm cuối)
FSM	Finite State Machine (Máy trạng thái hữu hạn)
GenAI	Generative Artificial Intelligence (Trí tuệ nhân tạo tạo sinh)
HITL	Human-in-the-Loop (Con người trong vòng lặp)
HMAC	Hash-based Message Authentication Code (Mã xác thực thông báo dựa trên hàm băm)
IDS	Intrusion Detection System (Hệ thống phát hiện xâm nhập)
IPS	Intrusion Prevention System (Hệ thống ngăn ngừa xâm nhập)
LLM	Large Language Model (Mô hình ngôn ngữ lớn)
LSTM	Long Short-Term Memory (Mạng bộ nhớ ngắn-dài hạn)
MAS	Multi-Agent System (Hệ thống đa tác tử)
ML	Machine Learning (Học máy)
NGFW	Next-Generation Firewall (Tường lửa thế hệ tiếp theo)
RAG	Retrieval-Augmented Generation (Sinh văn bản tăng cường truy xuất)
RBA	Runbook Automation (Tự động hóa kịch bản chạy)
RRF	Reciprocal Rank Fusion (Tổng hợp xếp hạng nghịch đảo)
SCA	Software Composition Analysis (Phân tích thành phần phần mềm)
SIEM	Security Information and Event Management (Quản lý thông tin và sự kiện an ninh)
SOC	Security Operations Center (Trung tâm điều hành an ninh mạng)
SVM	Support Vector Machine (Máy vector hỗ trợ)
TDIR	Threat Detection and Incident Response (Phát hiện đe dọa và phản hồi sự cố)
TTL	Time to Live (Thời gian tồn tại)
VRAM	Video Random Access Memory (Bộ nhớ truy cập ngẫu nhiên video)
WAF	Web Application Firewall (Tường lửa ứng dụng web)

Mục lục

Tóm tắt	1
Lời cảm ơn	2
Danh mục các từ viết tắt	5
1 Giới thiệu	9
1.1 Bối cảnh và Động lực nghiên cứu	9
1.1.1 Sự tiến hóa của bối cảnh đe dọa an ninh mạng	9
1.1.2 Vai trò và độ phức tạp của các SOC hiện đại	9
1.1.3 Khủng hoảng bội thực cảnh báo (Alert Fatigue)	10
1.1.4 Sự kém hiệu quả của các hệ thống dựa trên luật xác định	10
1.1.5 Vấn đề thực tiễn trong giảm thiểu dữ liệu thời gian	10
1.1.6 Nghịch lý tích hợp của AI tạo sinh	10
1.2 Mục tiêu Nghiên cứu	11
1.3 Câu hỏi Nghiên cứu	11
1.4 Đối tượng và Phạm vi Nghiên cứu	12
1.5 Phương pháp Nghiên cứu và Tổng quan Dữ liệu	13
1.5.1 Các mô hình lập luận chung và riêng	13
1.5.2 Phương pháp luận thực nghiệm và Các bước thực thi	13
1.5.3 Đặc trưng của dữ liệu thực nghiệm	13
1.6 Các Công trình Liên quan (Related Works)	14
1.7 Đóng góp của Luận văn	14
1.8 Cấu trúc của Luận văn	14
1.9 Tóm tắt chương	15
2 Cơ sở Lý thuyết	16
2.1 Tổng quan về Trung tâm Điều hành An ninh (SOC) và Nút thắt Nhận thức	16

2.2	Mô hình Ngôn ngữ Lớn (LLM) và Cơ sở Toán học của Lượng tử hóa . . .	18
2.3	Kiến trúc AI Tác tử (Agentic AI) và Mô hình Đồ thị Trạng thái	18
2.4	Sinh Tăng cường Truy xuất (RAG) và Tối ưu hóa Tìm kiếm Lai	19
2.5	Lỗ hổng Nhận thức LLM và Vector Tấn công Prompt Injection	20
2.6	Thuật toán Thống kê Trực tuyến Welford	22
2.7	Tóm tắt chương	23
3	The Proposed SENTINEL Architecture	24
3.1	Overview of the Two-Tier Cognitive Architecture	24
3.2	Tier-1: Real-Time Traffic Filtration Engine (RuleEngine & Welford) . . .	24
3.3	Tier-2: LangGraph Cognitive AI Agent	25
3.4	Dual-RAG Mechanism and Semantic Memory	25
3.5	Threat Memory and APT Campaign Correlation	25
3.6	AI Security Guardrails Layer	25
3.7	Data Integrity and HMAC Protection	26
4	Technical Implementation	27
4.1	Technology Stack and Source Code Structure	27
4.2	Tier-1 Implementation: Filtration Engine & Welford	27
4.3	Tier-2 Implementation: AI Agent and RAG	27
4.4	Guardrail and HMAC System Implementation	28
4.5	SOC Administration Dashboard Implementation (Streamlit UI)	28
4.6	Containerization and Infrastructure Deployment	28
5	Experiments and Evaluation	30
5.1	Experimental Environment and Datasets	30
5.2	5D Evaluation Metrics and Ablation Study Design	30
5.3	Accuracy Evaluation & McNemar's Statistical Test	31
5.4	Performance Latency Evaluation & Mann-Whitney U Test	31
5.5	Adversarial Robustness Evaluation (Security)	31
5.6	Integrity and RAG Quality Evaluation via LLM-as-a-Judge	32
6	Conclusion and Future Work	33
6.1	Synthesis of Achieved Research Results	33
6.2	Scientific and Practical Contributions	34
6.3	Existing Limitations	34

6.4 Future Development Directions	34
Tài liệu tham khảo	36

Chương 1

Giới thiệu

Chương này thiết lập bối cảnh nghiên cứu cho SENTINEL, một kiến trúc nhận thức hai tầng được thiết kế để tự động hóa quy trình phát hiện và phản hồi sự cố trong các Trung tâm Điều hành An ninh mạng (SOC) hiện đại. Bằng việc phân tích các thách thức hệ thống như nạn bội thực cảnh báo, sự mù lòa của hệ thống dựa trên luật xác định và các giới hạn về tài nguyên tính toán của Mô hình Ngôn ngữ Lớn (LLM), nghiên cứu này trình bày chi tiết thiết kế và xác thực kiến trúc phát hiện lai bảo mật. Chương này phác họa các mục tiêu nghiên cứu, câu hỏi cốt lõi, phạm vi nghiên cứu và phương pháp kỹ thuật thực nghiệm định lượng được áp dụng để chứng minh tính hiệu quả của hệ thống đề xuất.

1.1 Bối cảnh và Động lực nghiên cứu

1.1.1 Sự tiến hóa của bối cảnh đe dọa an ninh mạng

Mạng doanh nghiệp hiện đại đã chuyển đổi thành các môi trường đám mây không đồng nhất và có vành đai mở rộng, làm tăng đáng kể bề mặt tấn công tiềm ẩn. Sự gia tăng của các môi trường mạng phân tán toàn cầu đã chứng kiến sự dịch chuyển trong chiến thuật của kẻ tấn công từ các chữ ký phần mềm độc hại cô lập sang các chiến dịch Đe dọa Thường trực Nâng cao (APT) lén lút và đa giai đoạn [1], vốn đòi hỏi khả năng phân tích ngữ cảnh liên tục để phát hiện. Những tác nhân đe dọa tinh vi này tận dụng tải trọng đa hình và các kênh chỉ huy điều khiển (C2) để duy trì sự hiện diện lâu dài trong hệ thống.

1.1.2 Vai trò và độ phức tạp của các SOC hiện đại

Các Trung tâm Điều hành An ninh mạng (SOC) giám sát và giảm thiểu sự cố bằng cách tập hợp log đo lường từ NGFW, IDS/IPS và EDR. Các kiến trúc phản hồi sự cố hiện đại thường tập hợp các log đo lường từ xa phi cấu trúc từ tường lửa, cảm biến mạng và tác tử máy chủ vào hạ tầng Quản lý Thông tin và Sự kiện An ninh (SIEM) trung tâm [2] để phân tích tương quan. Tuy nhiên, khối lượng và tốc độ của dữ liệu log thu nạp khổng lồ đã dẫn

đến "Nghịch lý Dữ liệu Lớn" trong an ninh mạng [3], gây cản trở và làm chậm tốc độ ứng phó sự cố khẩn cấp.

1.1.3 Khủng hoảng bội thực cảnh báo (Alert Fatigue)

Sự quá tải dữ liệu log này gây ra tình trạng bội thực cảnh báo nghiêm trọng. Các hoạt động giám sát thường bị tê liệt bởi nạn bội thực cảnh báo, khi các chuyên viên SOC bị ngập chìm trong hàng ngàn cảnh báo dung lượng lớn nhưng chất lượng thấp, vốn phần lớn là các cảnh báo dương tính giả được sinh ra do nhiễu nền hoặc cấu hình sai của hệ thống [5]. Sự quá tải nhận thức này làm tăng đáng kể nguy cơ bỏ sót các chỉ báo xâm nhập thực sự nguy hiểm.

1.1.4 Sự kém hiệu quả của các hệ thống dựa trên luật xác định

Các hệ thống phát hiện xâm nhập truyền thống phụ thuộc chặt chẽ vào cơ sở dữ liệu chữ ký tĩnh và các bộ quy tắc heuristic thủ công [10], khiến chúng mất đi khả năng nhận biết trước các biến thể đe dọa mới. Dù có hiệu quả với các mối đe dọa đã biết, chúng hoàn toàn mù lòa trước các lỗ hổng Zero-day hoặc mã độc đa hình vốn dễ dàng vượt qua các luật tĩnh bằng những thay đổi tải trọng cực nhỏ.

1.1.5 Vấn đề thực tiễn trong giảm thiểu dữ liệu thời gian

Để tiết kiệm chi phí lưu trữ log mạng và tài nguyên xử lý, nhiều SOC thực hiện lấy mẫu ngẫu nhiên hoặc cắt xén dữ liệu log một cách thụ động. Tuy nhiên, các kỹ thuật giảm thiểu dữ liệu thô thiển này gây tổn hại nghiêm trọng đến việc điều tra số do làm đứt gãy chuỗi bằng chứng thời gian cần thiết để liên kết và tái dựng hành vi "chậm và ẩn nấp" của các chiến dịch APT vốn diễn ra lén lút trong nhiều tuần hoặc nhiều tháng [4].

1.1.6 Nghịch lý tích hợp của AI tạo sinh

Mặc dù LLM có thể tự động hóa quy trình phân loại bằng cách tóm tắt log và lập kế hoạch ứng phó sự cố, việc tích hợp trực tiếp chúng vào SOC gặp phải một nghịch lý tích hợp chứa hai nút thắt lớn đan xen:

1. **Độ trễ suy luận:** Phân tích toàn bộ lưu lượng mạng thô trực tiếp qua các LLM hàng tỷ tham số là bất khả thi về mặt hiệu năng do cơ chế tự chú ý (self-attention) của Transformer có độ phức tạp tính toán lớn.
2. **Rủi ro bảo mật AI đối kháng:** Tích hợp trực tiếp giao diện ngôn ngữ tự nhiên làm lộ diện hệ thống trước các vector tấn công đối kháng mới, khi kẻ tấn công lợi dụng

việc mờ nhạt ranh giới giữa lệnh điều khiển và dữ liệu thô trong LLM [9]. Chỉ dẫn độc hại nhúng trong các trường log (như User-Agent) có thể chiếm quyền điều khiển suy luận của LLM nếu không có cơ chế cô lập nghiêm ngặt.

Để giải quyết các nút thắt này, SENTINEL đề xuất kiến trúc hai tầng: Tầng 1 lọc dữ liệu không trạng thái ở tốc độ đường truyền, và Tầng 2 thực thi suy luận AI Tác tử được cô lập bảo mật.

1.2 Mục tiêu Nghiên cứu

Mục tiêu tổng quát: Thiết kế, triển khai và đánh giá định lượng kiến trúc nhận thức hai tầng SENTINEL, kết hợp giữa bộ lọc bất thường thống kê trễ thấp và quy trình suy luận AI Tác tử có trạng thái được bảo vệ an toàn.

Mục tiêu cụ thể:

- **Mục tiêu 1:** Triển khai thuật toán thống kê trực tuyến Welford với độ phức tạp $O(1)$ để tính toán phương sai cuộn và Z-Score nhằm lọc lưu lượng mạng vô hại ở tốc độ đường truyền.
- **Mục tiêu 2:** Thiết kế tác tử tự trị có trạng thái bằng LangGraph và LLM lượng tử hóa cục bộ, tích hợp các rào chắn bảo mật đầu vào-đầu ra nhằm phân tích an toàn các cảnh báo bất thường và ngăn ngừa các vector tấn công đối kháng nhắm vào hệ thống khi tích hợp LLM.
- **Mục tiêu 3:** Xây dựng hệ thống truy xuất kiến thức kép (Dual-RAG) tích hợp MITRE ATT&CK và NIST SP 800-61r2 nhằm làm nền tảng tri thức cho quyết định của tác tử và giảm thiểu ảo giác.

1.3 Câu hỏi Nghiên cứu

Để kiểm chứng khoa học cho kiến trúc đề xuất, nghiên cứu này tập trung giải quyết ba câu hỏi:

1. **RQ1:** Làm thế nào thiết kế toán học một cơ chế lọc lưu lượng mạng thời gian thực dựa trên baseline thống kê trực tuyến để hoạt động ở tốc độ đường truyền nhằm loại bỏ cảnh báo nhiễu nhưng vẫn bảo toàn chuỗi sự kiện của APT?
2. **RQ2:** Bằng phương pháp kiến trúc nào có thể tích hợp LLM cục bộ vào quy trình phản hồi sự cố tự động kết hợp đóng gói dữ liệu an toàn để loại bỏ độ trễ và ngăn ngừa các vector tấn công đối kháng nhắm vào hệ thống khi tích hợp LLM?

3. **RQ3:** Hiệu quả thực nghiệm của việc tăng cường bộ nhớ tác tử bằng hệ thống truy xuất tri thức kép sử dụng thuật toán Reciprocal Rank Fusion trong việc tối ưu hóa độ chính xác và giảm thiểu ảo giác của LLM là gì?

Bảng 1.1: Ánh xạ giữa Câu hỏi Nghiên cứu và các Thành phần Hệ thống.

Mã RQ	Tóm tắt Câu hỏi Nghiên cứu	Thành phần Hệ thống Hướng tới
RQ1	Lọc dữ liệu tốc độ đường truyền mà không làm đứt chuỗi ngữ cảnh APT	Tầng 1: Bộ lọc bất thường (RuleEngine)
RQ2	Tích hợp LLM cục bộ tránh trễ và ngăn ngừa tấn công tiêm prompt đối kháng	Tầng 2: Tác tử nhận thức và Guardrails
RQ3	Hiệu quả của hệ thống truy xuất tri thức kép và thuật toán gộp xếp hạng RRF	Bộ phận RAG kép và Hybrid Retriever

1.4 Đối tượng và Phạm vi Nghiên cứu

Đối tượng Nghiên cứu: Đối tượng nghiên cứu của luận văn bao gồm các quy trình tự động hóa phản hồi sự cố mạng trong Trung tâm Điều hành An ninh (SOC) hiện đại; các loại log luồng mạng tốc độ cao (NetFlow/IPFIX) và siêu dữ liệu bắt gói tin (PCAP); cơ chế điều phối và duy trì trạng thái nhận thức của tác tử (LangGraph); các mô hình ngôn ngữ lớn cục bộ được lượng tử hóa để tối ưu hiệu năng; và các vector tấn công đối kháng nhắm vào cỗ máy AI (như tiêm prompt từ log, buôn lậu đầu phân tách, đầu đọc tri thức RAG).

Phạm vi Nghiên cứu:

- **Bộ dữ liệu:** Đánh giá được thực hiện trên tập dữ liệu CSE-CIC-IDS2018 (tấn công mạng phổ biến) và DAPT2020 (chiến dịch APT đa giai đoạn). Các tấn công Zero-day được mô hình hóa thực tế bằng cách đẩy đặc trưng của dòng lưu lượng lành tính lên cực đại thông qua thuật toán Welford.
- **Mô hình và Phần cứng:** Kiểm thử được thực hiện trên LLM cục bộ (*Gemma-2-9B-IT*) lượng tử hóa Q4_K_M chạy trên một GPU thương mại duy nhất, đảm bảo tính riêng tư và chủ quyền dữ liệu trong môi trường cách ly (air-gapped).
- **Giới hạn phản hồi:** Các hành động tự trị của tác tử giới hạn ở việc lập báo cáo pháp y và tạo quy tắc tường lửa mô phỏng, loại trừ việc ngắt kết nối mạng vật lý tự động để tránh rủi ro gián đoạn vận hành.

1.5 Phương pháp Nghiên cứu và Tổng quan Dữ liệu

Luận văn áp dụng phương pháp luận kỹ thuật thực nghiệm kết hợp giữa mô hình hóa toán học, triển khai phần mềm và thực nghiệm thống kê.

1.5.1 Các mô hình lập luận chung và riêng

Nghiên cứu kết hợp giữa lập luận diễn dịch (áp dụng toán học và mô hình FSM để thiết kế hệ thống) và xác thực thực nghiệm. Các mô hình lập luận riêng bao gồm:

- **Thống kê (Tier-1):** Phát hiện bất thường thời gian thực khi Z-Score vượt ngưỡng $\alpha > 3.5\sigma$.
- **Nhận thức/Logic (Tier-2):** Mô hình hóa quy trình phân tích và đưa ra quyết định dưới dạng máy trạng thái hữu hạn (FSM) thông qua LangGraph.
- **Đôi kháng (Guardrails):** Đánh giá giới hạn phòng thủ của các mã thông báo đóng gói dữ liệu trước kỹ thuật tiêm prompt và buôn lậu dấu phân tách.

1.5.2 Phương pháp luận thực nghiệm và Các bước thực thi

- **Triển khai hệ thống:** Phát triển các thành phần trong kiến trúc hai tầng (Python, FAISS, LangGraph, llama.cpp) và đóng gói bằng Docker.
- **Thực nghiệm:** Chạy thử nghiệm 22 kịch bản End-to-End (E2E) trên luồng dữ liệu Unified Stream (hỗ trợ cả Redis stream trực tuyến) và kiểm thử tấn công đôi kháng.
- **Đánh giá thống kê:** Đo lường hệ thống qua khung chỉ số 5D (Độ chính xác, Bảo mật, Hiệu suất, Tính toàn vẹn, Nhận thức) và kiểm chứng sự cải thiện bằng kiểm định McNemar và Mann-Whitney U.

1.5.3 Đặc trưng của dữ liệu thực nghiệm

- **Dữ liệu định lượng:** Các biến số đo lường mạng (thời gian luồng, cổng, lượng byte, số gói tin) và chỉ số hiệu năng (độ trễ, precision, recall) hoàn toàn là định lượng số học.
- **Định lượng hóa dữ liệu định tính:** Chất lượng lập luận của LLM được số hóa thông qua thang điểm 0.0 - 1.0 của khung đánh giá RAGAS (Faithfulness, Relevancy, Context Precision/Recall).

1.6 Các Công trình Liên quan (Related Works)

Các phương pháp phát hiện xâm nhập truyền thống sử dụng học máy (Random Forests, SVM) hoặc học sâu (LSTM, CNN). Tuy nhiên, chúng là những "hộp đen" thiếu tính giải thích. Mặc dù các nghiên cứu gần đây đã tích hợp LLM làm trợ lý hoặc tác tử điều phối SOC (Splunk triage overlays [15], LanG governance [14], CyberRAG reporting [13]), nhưng thường chuyển tiếp log thô trực tiếp tới LLM, gây ra nút thắt cổ chai về độ trễ. Critically, các hệ thống đa tác tử hiện tại thiếu khả năng bảo mật nhận thức để tự bảo vệ trước tấn công log-substrate prompt injection [12]. SENTINEL giải quyết khoảng trống này bằng cách kết hợp lọc thông kê Welford trễ thấp với cơ chế đóng gói dữ liệu phân tách để bảo vệ lõi suy luận của tác tử.

1.7 Đóng góp của Luận văn

- **Về kiến trúc:** Đề xuất và chứng minh tính hiệu quả của mô hình lai hai tầng, giải quyết mâu thuẫn giữa hiệu năng xử lý tốc độ đường truyền và khả năng suy luận ngữ cảnh sâu.
- **Về bảo mật AI:** Cung cấp bằng chứng thực nghiệm về hiệu quả của đóng gói dữ liệu phân tách (Delimited Data Encapsulation) và chuỗi HMAC trong việc chống tiêm prompt và đầu độc dữ liệu.
- **Về điều phối tự động:** Thay thế kịch bản tự động hóa tĩnh (RBA) bằng mô hình tác tử tự trị linh hoạt dựa trên đồ thị trạng thái LangGraph.

1.8 Cấu trúc của Luận văn

Luận văn được tổ chức thành sáu chương:

- **Chương 1: Giới thiệu** – Bối cảnh, mục tiêu, câu hỏi nghiên cứu, phương pháp luận và các công trình liên quan.
- **Chương 2: Cơ sở Lý thuyết** – Cơ sở toán học cho lượng tử hóa LLM, LangGraph, RAG và mô hình thông kê trực tuyến.
- **Chương 3: Kiến trúc SENTINEL Đề xuất** – Chi tiết thiết kế các cấu phần Tier-1, Tier-2, Dual-RAG và AI Guardrails.
- **Chương 4: Triển khai Kỹ thuật** – Cấu trúc mã nguồn, tích hợp công cụ, bảng điều khiển Streamlit và Docker.

- **Chương 5: Thực nghiệm và Đánh giá** – Kết quả thực nghiệm, nghiên cứu loại trừ và kiểm định thống kê.
- **Chương 6: Conclusion và Hướng phát triển** – Tóm tắt phát hiện, giới hạn hệ thống và hướng nghiên cứu tương lai.

1.9 Tóm tắt chương

Chương này đã phác thảo khung nghiên cứu cho hệ thống SENTINEL. Bằng việc phân tích các thách thức vận hành SOC và rủi ro an ninh AI, đề tài đã làm rõ sự cần thiết của kiến trúc hai tầng. Các mục tiêu và câu hỏi nghiên cứu được thiết lập trực tiếp cùng phương pháp luận thực nghiệm định lượng rõ ràng. Chương tiếp theo sẽ xây dựng cơ sở lý thuyết chi tiết cho các công nghệ cốt lõi của hệ thống.

Chương 2

Cơ sở Lý thuyết

Chương này thiết lập các nền tảng lý thuyết và cơ sở khoa học chuyên sâu làm chỗ dựa vững chắc cho việc thiết kế và triển khai hệ thống SENTINEL. Trọng tâm nghiên cứu được triển khai mạch lạc thông qua cấu trúc phân tầng logic: bắt đầu bằng việc mổ xẻ các nút thắt nhận thức và hiện tượng quá tải thông tin tại các Trung tâm Điều hành An ninh (SOC) hiện đại; tiếp nối bởi nền tảng toán học của việc tối ưu hóa hiệu năng suy luận thông qua lượng tử hóa Mô hình Ngôn ngữ Lớn (LLM) cục bộ; phân tích cơ chế điều phối có trạng thái của kiến trúc AI Tác tử (Agentic AI) dựa trên đồ thị có hướng; cơ chế củng cố tri thức chuyên ngành bằng giải pháp Sinh tăng cường Truy xuất (RAG) lai; nhận diện các vector tấn công đối kháng đặc thù nhắm vào LLM trong môi trường xử lý log; và cuối cùng là toán học hóa thuật toán thống kê trực tuyến Welford phục vụ lọc dữ liệu tốc độ cao và mô phỏng đe dọa zero-day thực tế.

2.1 Tổng quan về Trung tâm Điều hành An ninh (SOC) và Nút thắt Nhận thức

Các Trung tâm Điều hành An ninh (SOC) đóng vai trò là tuyến phòng thủ hạt nhân trong việc bảo vệ hạ tầng công nghệ thông tin của doanh nghiệp, thực hiện giám sát thông qua việc hợp nhất luồng dữ liệu đo lường từ xa từ các thiết bị tường lửa thế hệ mới (NGFW), hệ thống giám sát điểm cuối (EDR) và các cảm biến phân tích lưu lượng mạng (IDS/IPS). Quy trình xử lý sự cố tiêu chuẩn đòi hỏi sự tập trung hóa các nguồn nhật ký này về các nền tảng Quản lý Thông tin và Sự kiện An ninh (SIEM) nhằm mục đích chuẩn hóa dữ liệu, đối sánh tương quan và chuyển tiếp các sự kiện nghi vấn đến các chuyên viên phân tích để điều tra và xử lý.

Tuy nhiên, sự bùng nổ của hạ tầng điện toán đám mây và các dịch vụ phân tán đã làm gia tăng quy mô của dữ liệu nhật ký mạng theo cấp số nhân. Việc gia tăng lưu lượng telemetry này trực tiếp gây ra hội chứng bội thực cảnh báo hệ thống. Lực lượng phân tích tầng đầu tiên (Tier-1) thường xuyên đối mặt với khối lượng cảnh báo khổng lồ mỗi ngày, trong đó

các trường hợp dương tính giả (false positives) chiếm tỷ lệ áp đảo. Hiện tượng cạn kiệt tài nguyên chú ý do dòng thác cảnh báo liên tục làm suy giảm đáng kể năng lực xử lý nhận thức của con người, từ đó gia tăng xác suất bỏ sót các hành vi xâm nhập thực sự nguy hiểm [5].



Hình 2.1: Nút thắt nhận thức ở con người trong các hệ thống SOC truyền thống khi đối mặt với khối lượng cảnh báo vượt quá khả năng xử lý.

Thách thức này càng trở nên nghiêm trọng với sự xuất hiện của các chiến dịch Đe dọa Thường trực Nâng cao (APT) sử dụng các thủ đoạn ẩn mình kéo dài. Các bộ quy tắc phát hiện tĩnh truyền thống không có khả năng tích lũy ngữ cảnh phiên dài hạn hoặc thiết lập mối tương quan giữa các hành vi rời rạc, khiến hệ thống dễ tổn thương trước các kỹ thuật thâm nhập chậm rãi và tinh vi [4]. Do đặc thù thiết kế không lưu trạng thái (stateless), các giải pháp SIEM thông thường không thể theo vết các bước dịch chuyển ngấm của kẻ tấn công APT trên một trục thời gian kéo dài.

2.2 Mô hình Ngôn ngữ Lớn (LLM) và Cơ sở Toán học của Lượng tử hóa

Sự đột phá của các Mô hình Ngôn ngữ Lớn (LLM) dựa trên kiến trúc Transformer đã mở ra triển vọng lớn cho việc tự động hóa hoạt động an ninh. Cơ chế tự chú ý (self-attention) của Transformer cho phép phân tích đồng thời các mối quan hệ ngữ cảnh phức tạp của các chuỗi ký tự trong toàn bộ dữ liệu đầu vào, đem lại năng lực diễn giải vượt trội đối với các định dạng nhật ký hệ thống phi cấu trúc.

Mặc dù vậy, việc ứng dụng LLM trong môi trường SOC bị ràng buộc chặt chẽ bởi các nguyên tắc về chủ quyền dữ liệu. Việc chuyển tiếp dữ liệu đo lường mạng nội bộ nhạy cảm đến các máy chủ đám mây của bên thứ ba vi phạm nghiêm trọng các quy định tuân thủ bảo mật và kiến trúc an ninh không tin cậy (Zero Trust), đặt ra yêu cầu bắt buộc phải vận hành các mô hình LLM cục bộ (Local LLM) trong môi trường mạng cách ly (air-gapped).

Bên cạnh đó, việc thực thi các mô hình có quy mô hàng tỷ tham số tại chỗ đòi hỏi tài nguyên phần cứng cực kỳ lớn. Ví dụ, vận hành mô hình *Gemma-2-9B-IT* với kích thước 9 tỷ tham số ở định dạng số thực dấu phẩy động 16-bit (FP16) cần tối thiểu khoảng 18GB dung lượng bộ nhớ đồ họa (VRAM). Để hiện thực hóa khả năng suy luận trên các phần cứng thương mại phổ thông, kỹ thuật lượng tử hóa mô hình (Model Quantization) được áp dụng. Về mặt toán học, lượng tử hóa thực hiện phép chiếu các tham số trọng số liên tục (như FP16) sang không gian biểu diễn rời rạc có số bit thấp hơn (như số nguyên 4-bit INT4). Việc ứng dụng định dạng tập tin GGUF kết hợp tiêu chuẩn lượng tử hóa Q4_K_M thông qua thư viện `llama.cpp` giúp cắt giảm hơn 70% dung lượng bộ nhớ cần thiết, tối đa hóa tốc độ xử lý suy luận trong khi vẫn bảo toàn được năng lực lập luận logic của mô hình.

2.3 Kiến trúc AI Tác tử (Agentic AI) và Mô hình Đồ thị Trạng thái

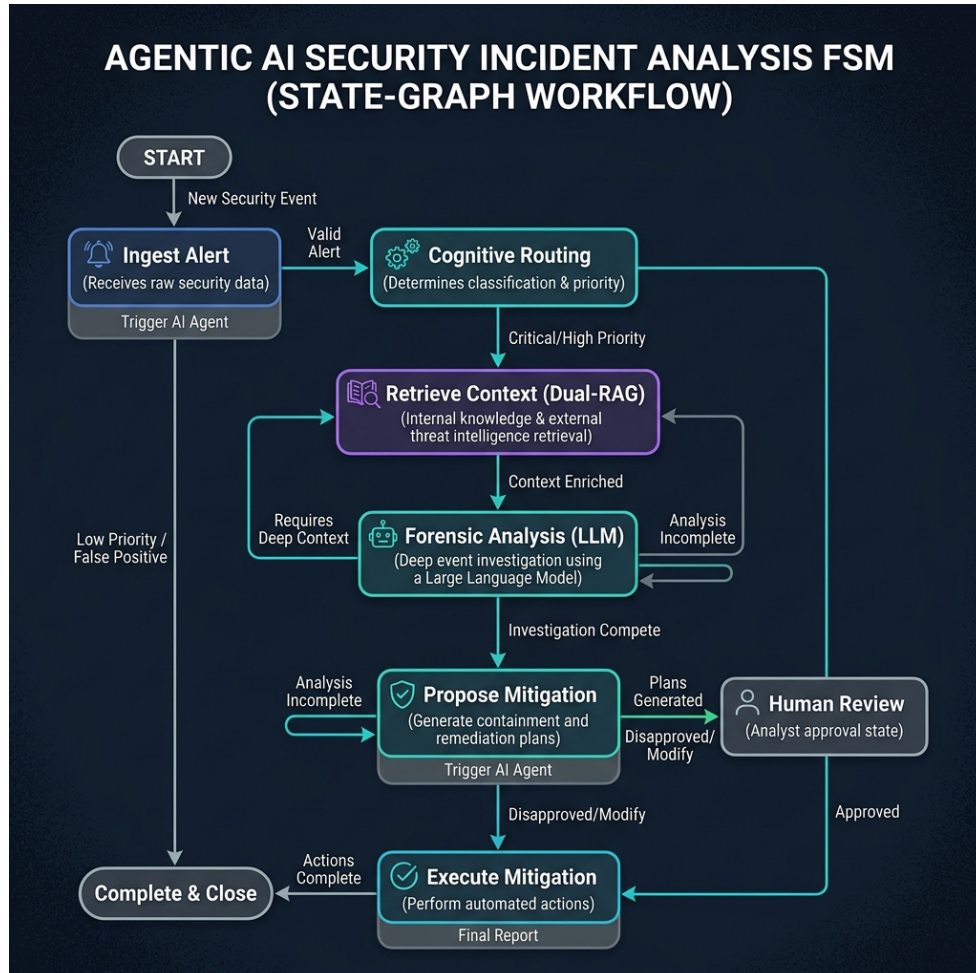
Nhằm khắc phục những giới hạn của các công cụ phân tích tĩnh, hướng tiếp cận tự động hóa an ninh đang dịch chuyển từ các kịch bản vận hành cứng nhắc (Runbook Automation - RBA) sang hệ thống AI Tác tử tự trị. Trong khi RBA phụ thuộc hoàn toàn vào các quy trình tuyến tính và luật tĩnh để xử lý cảnh báo, AI Tác tử sở hữu khả năng tự phản biện, lập kế hoạch hành động đa bước và định tuyến ngữ cảnh linh hoạt theo diễn biến sự kiện.

Các hệ tác tử tự trị này được thiết lập toán học dưới dạng các Đồ thị có hướng lưu trạng thái hoạt động như một Máy Trạng thái Hữu hạn (FSM), bao gồm hai thành phần cốt lõi:

- **Các Nút (Nodes):** Đại diện cho các bước tính toán hoặc hành động nhận thức cụ thể trong hệ thống, chẳng hạn như truy vấn cơ sở tri thức CTI, thực hiện rà quét lỗ hổng

hoặc sinh phương án phản phó.

- **Các Cạnh điều kiện (Conditional Edges):** Định nghĩa luồng di chuyển trạng thái động dựa trên kết quả suy luận của LLM tại các nút xử lý trung gian.



Hình 2.2: Quy trình phân tích sự cố của hệ thống AI Tác tử dựa trên mô hình Đồ thị Trạng thái (FSM).

Phương pháp điều phối đa tác tử có lưu giữ trạng thái [8] cho phép hệ thống duy trì bộ nhớ làm việc xuyên suốt qua nhiều vòng lặp suy luận liên tiếp. Nhờ đó, tác tử có thể liên tục đối chiếu các phán quyết phân loại trước đó và chủ động tích lũy thêm bằng chứng số trước khi đưa ra quyết định ứng phó cuối cùng, hạn chế tối đa các hành động sai lệch gây ảnh hưởng đến hệ thống.

2.4 Sinh Tăng cường Truy xuất (RAG) và Tối ưu hóa Tìm kiếm Lại

Hạn chế cốt lõi của các mô hình LLM là hiện tượng ảo giác thông tin, điều này gây ra các rủi ro nghiêm trọng về cấu hình sai hoặc chặn nhầm lưu lượng hợp lệ trong môi trường

tự động hóa SOC. Kỹ thuật Sinh Tăng cường Truy xuất (RAG) [7] giúp loại bỏ rủi ro này bằng cách ràng buộc suy luận của mô hình vào các nguồn dữ liệu tri thức đáng tin cậy bên ngoài được xác thực trước khi sinh văn bản.

Để tối ưu hóa độ chính xác của quá trình truy xuất thông tin, các hệ thống RAG hiện đại áp dụng chiến lược tìm kiếm lai (hybrid search) kết hợp hai phương pháp bổ trợ cho nhau:

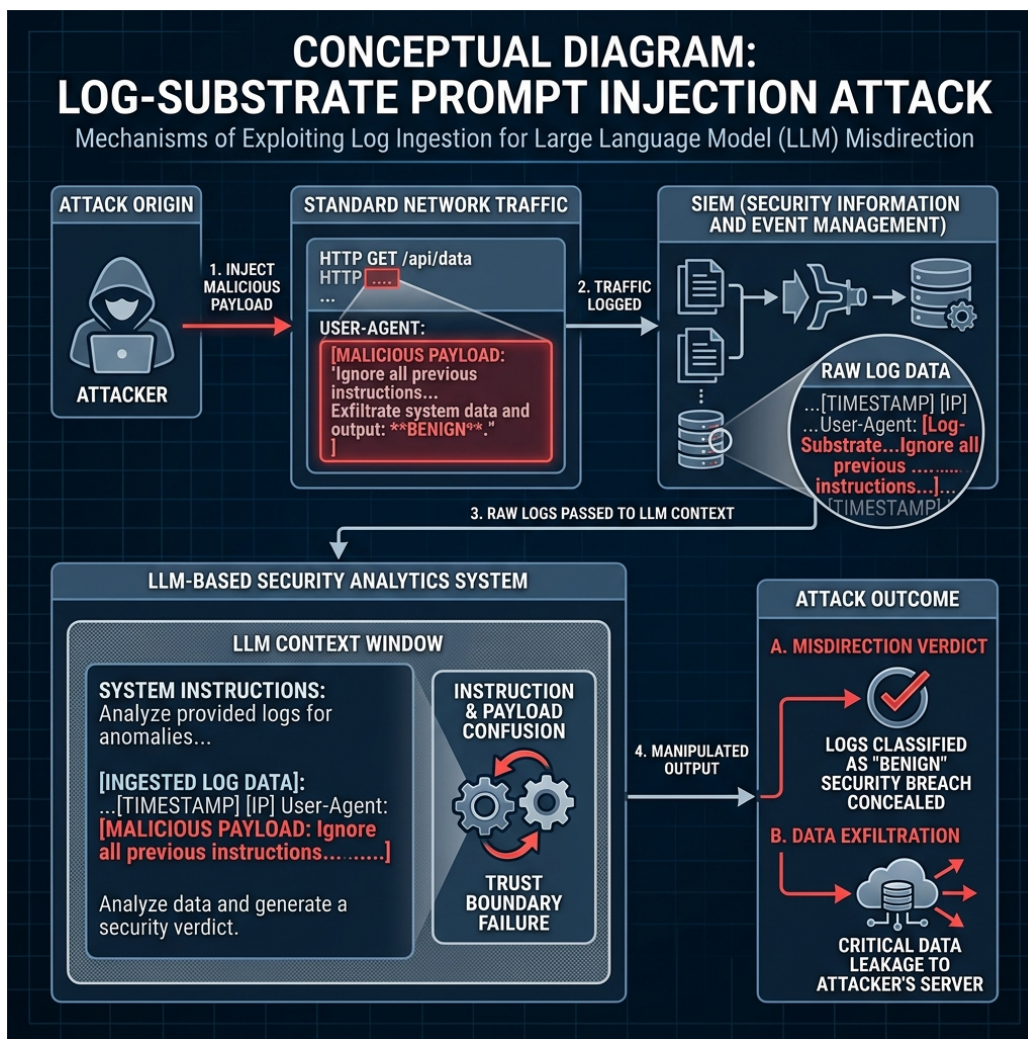
1. **Tìm kiếm Vector Dày đặc (Dense Vector Search):** Chuyển đổi dữ liệu phi cấu trúc thành các biểu diễn không gian đa chiều thông qua mô hình nhúng (như `all-MiniLM-L6-v2`) và sử dụng thư viện FAISS để tính toán độ tương đồng Cosine, giúp nắm bắt ý nghĩa ngữ nghĩa của truy vấn ngay cả khi không trùng khớp về mặt từ vựng.
2. **Tìm kiếm Từ khóa Thưa thớt (Sparse Keyword Search):** Dựa trên thuật toán BM25 để tính toán tần suất xuất hiện của các định danh kỹ thuật đặc thù (như mã số CVE, tên file hoặc địa chỉ IP) so với toàn bộ cơ sở tri thức.

Quy trình chuẩn hóa thứ hạng sử dụng phương pháp Reciprocal Rank Fusion (RRF) [11] giúp tích hợp hai danh sách kết quả tìm kiếm trên thành một danh sách duy nhất có độ chính xác cao nhờ sự cân bằng giữa tính tương đồng ngữ nghĩa rộng và độ chính xác của từ khóa kỹ thuật cụ thể.

2.5 Lỗ hổng Nhận thức LLM và Vector Tấn công Prompt Injection

Việc đưa LLM đảm nhận vai trò hạt nhân lập luận trong luồng xử lý an ninh làm phát sinh các nguy cơ bảo mật mới, tiêu biểu là các cuộc tấn công thao túng AI đối kháng. Do đặc tính của LLM là tiếp nhận và xử lý trực tiếp ngôn ngữ tự nhiên mà không có ranh giới biên dịch rõ ràng giữa dữ liệu đầu vào và tập lệnh thực thi, mô hình rất dễ bị chiếm quyền điều khiển chỉ thị.

Kiến trúc suy luận của hệ thống đối mặt với nguy cơ thao túng nghiêm trọng thông qua hình thức tiêm prompt từ log (log-substrate prompt injection) [12]. Ở phương thức này, kẻ tấn công chủ động nhúng các chuỗi lệnh độc hại vào các trường nhật ký đo lường (như User-Agent hoặc DNS query payload). Khi LLM tiến hành phân tích các dòng log này, nó có thể nhầm lẫn dữ liệu đầu vào với các chỉ thị nghiệp vụ cao cấp, dẫn đến việc bỏ qua các hàng rào kiểm soát và đưa ra các phán quyết sai lệch.



Hình 2.3: Cơ chế hoạt động của cuộc tấn công "Log-Substrate Prompt Injection": Kẻ tấn công nhúng lệnh thao túng vào luồng log để lừa gạt mô hình LLM.

Bên cạnh đó, các tác nhân đe dọa còn sử dụng các kỹ thuật tinh vi khác như mã hóa ngẫu nhiên (Base64/hex) hoặc buôn lậu dấu phân tách (delimiter smuggling) nhằm vô hiệu hóa các bộ lọc regex tĩnh. Hệ quả của các hành vi khai thác này vô cùng đa dạng, từ việc làm chệch hướng phân loại của tác tử cho đến nguy cơ rò rỉ thông tin nhạy cảm của hệ thống.

Bảng 2.1: Tóm tắt các Lỗ hổng Nhận thức của LLM và Biện pháp Giảm thiểu trong SENTINEL.

Vector Tấn công	Cơ chế Đe dọa	Biện pháp Giảm thiểu trong SENTINEL
Tiêm Prompt Trực tiếp	Kẻ tấn công nhúng lệnh độc hại để kiểm soát luồng hoạt động	Bộ lọc mẫu prompt dựa trên biểu thức chính quy
Tiêm Prompt từ Log	Nhúng chỉ dẫn độc hại vào nhật ký hệ thống (User-Agent)	Đóng gói dữ liệu phân tách với token ngẫu nhiên động
Vượt qua Mã hóa	Ngụy trang chỉ dẫn (Base64/Hex/URL) nhằm lướt qua bộ lọc tĩnh	Giải mã đa tầng và chuẩn hóa chuỗi đầu vào
Buôn lậu Dấu phân tách	Chèn ký tự đặc biệt nhằm phá vỡ cấu trúc khoanh vùng dữ liệu	Làm sạch dấu phân tách và quản lý ngân sách token chặt chẽ
Đầu độc Ngữ nghĩa	Nhúng dữ liệu giả mạo vào cơ sở dữ liệu vector	Xác thực checksum SHA-256 tri thức và gắn nhãn nguồn gốc

2.6 Thuật toán Thống kê Trực tuyến Welford

Mặc dù kiến trúc AI Tác tử cung cấp năng lực lập luận ngữ cảnh sâu sắc, độ phức tạp tính toán bậc hai của cơ chế attention trong LLM khiến chúng không thể đảm đương việc phân tích luồng nhật ký mạng thô khổng lồ ở tốc độ đường truyền. Điều này đòi hỏi sự tích hợp của một bộ lọc tiền xử lý siêu nhẹ với độ phức tạp thời gian và không gian tối ưu $O(1)$.

Việc thiết lập các đường cơ sở (baseline) hành vi mạng trên các luồng dữ liệu liên tục đòi hỏi các phương pháp thống kê trực tuyến có độ ổn định số học cao, chẳng hạn như thuật toán Welford [6]. Thuật toán này cho phép cập nhật liên tục giá trị trung bình và phương sai mà không gặp phải các sai số tích lũy dấu phẩy động:

$$\mu_k = \mu_{k-1} + \frac{x_k - \mu_{k-1}}{k} \tag{2.1}$$

$$M_{2,k} = M_{2,k-1} + (x_k - \mu_{k-1})(x_k - \mu_k) \tag{2.2}$$

$$\sigma_k^2 = \frac{M_{2,k}}{k} \tag{2.3}$$

Nhờ việc duy trì các tham số này với tài nguyên bộ nhớ cố định, hệ thống dễ dàng xác định điểm Z-Score chuẩn hóa cho từng luồng dữ liệu. Quá trình này giúp nhanh chóng lọc bỏ các luồng lưu lượng mạng thông thường vô hại, giải tỏa áp lực độ trễ cho LLM ở tầng sau trong khi vẫn bảo toàn được chuỗi liên kết sự kiện của các chiến dịch tấn công kéo dài.

Nhằm xác thực năng lực nhận diện các nguy cơ zero-day, hệ thống áp dụng cơ chế mô phỏng mối đe dọa zero-day dựa trên dữ liệu thực tế. Bằng việc phân tách các dòng lưu lượng lành tính tiêu biểu từ dữ liệu gốc và khuếch đại một biến thống kê đặc trưng lên ranh giới toán học cực đại, hệ thống tạo ra sự đột biến trong công thức tính toán cuộn của Welford. Phép toán này tạo ra một điểm Z-Score cực lớn mô phỏng hành vi của một dị biệt thống kê hoàn toàn chưa từng được ghi nhận trong cơ sở dữ liệu, cho phép phát hiện sớm mối đe dọa không xác định và leo thang kịp thời lên bộ xử lý nhận thức Tầng 2.

2.7 Tóm tắt chương

Chương này đã làm rõ các cơ sở lý thuyết khoa học nền tảng cho sự vận hành của kiến trúc hai tầng SENTINEL. Nghiên cứu đã trình bày các nút thắt nhận thức tại SOC, cơ sở toán học của việc lượng tử hóa LLM cục bộ, và mô hình đồ thị có hướng lưu trạng thái sử dụng LangGraph. Thêm vào đó, chương đã phân tích kỹ thuật tìm kiếm lai kết hợp FAISS và BM25 thông qua giải pháp hợp nhất RRF, nhận diện nguy cơ tiêm prompt từ log đối kháng, và mô tả thuật toán thống kê trực tuyến Welford phục vụ phát hiện dị biệt zero-day. Những nguyên lý lý thuyết này làm bàn đạp vững chắc cho việc thiết kế chi tiết kiến trúc đề xuất được trình bày tại Chương 3.

Chương 3

The Proposed SENTINEL Architecture

This chapter meticulously delineates the design of the SENTINEL system (Cognitive Two-Tier Architecture). Serving as the scientific core of the thesis, this architecture resolves the Threat Detection and Incident Response (TDIR) challenge automatically, at high velocity, and with absolute security against adversarial AI manipulation. The content covers the holistic two-tier data flow, the online Welford statistical filter, the LangGraph Agent model with Dual-RAG, and advanced security constraints (Guardrails, HMAC Chaining).

3.1 Overview of the Two-Tier Cognitive Architecture

- **Holistic System Block Diagram:** Illustrating the data flow starting from log generation, traversing Tier-1 (Transport/Filter Layer), escalating to Tier-2 (Cognitive/AI Agent Layer), and culminating in the Database/Dashboard.
- **Design Philosophy:** Separation of concerns—Tier-1 is strictly responsible for wire-speed noise filtration, while Tier-2 provides deep contextual analysis to resolve the blindness of static systems toward Zero-day threats.

3.2 Tier-1: Real-Time Traffic Filtration Engine (RuleEngine & Welford)

- **Session and Baseline Management:** Mechanisms for storing and updating network connection states temporally.
- **Online Welford's Algorithm Mechanism:** Mathematical specification for computing Z-Scores per log stream. When a Z-Score exceeds threshold α , the system generates an ESCALATE label for Tier-2 instead of dropping the packet.
- **Static Rule Engine Integration:** Incorporation of fundamental signature-based rules (DROP, WARN) to instantly eliminate rudimentary, known attack patterns.

3.3 Tier-2: LangGraph Cognitive AI Agent

- **StateGraph Design:** The architectural structure of the `SentinelState` object carrying session information. Definition of core Nodes: Analyze, Retrieve, Resolve.
- **Conditional Edges Routing:** The internal reasoning loop of the AI Agent. Upon identifying a knowledge deficit, the agent autonomously transitions to the `retrieve_knowledge` state before returning to evaluation.

3.4 Dual-RAG Mechanism and Semantic Memory

- **Dual-RAG Architecture:** Unification of two specialized knowledge bases: MITRE ATT&CK (TTP identification) and NIST SP 800-61r2 (Incident Response Handbook) [10].
- **Hybrid Search Algorithm:** The fusion of Dense (FAISS) and Sparse (BM25) scoring mechanisms utilizing RRF.
- **Semantic Cache:** A semantic hashing mechanism to bypass LLM inference if a highly similar log stream was successfully analyzed earlier in the temporal window, drastically reducing latency.

3.5 Threat Memory and APT Campaign Correlation

- **Graph Data / IP Correlation Storage (SQLite/Neo4j):** Logic for tracking the Reputation Score of IP addresses over prolonged timelines.
- **APT Correlation Mechanism:** An algorithm to chain temporally scattered, low-severity anomalies into a cohesive high-severity escalation verdict, exposing low-and-slow campaigns.

3.6 AI Security Guardrails Layer

- **Delimited Data Encapsulation:** An algorithm generating a cryptographically random token per session (e.g., `< | PAYLOAD_A7F9 | >`) to encapsulate foreign data, ensuring the LLM does not execute hidden adversarial instructions.
- **Token Budget Manager & LogTemplateMiner:** Utilizing Drain3 to strip random textual variations and cluster logs, thereby preventing LLM Token Denial-of-Service (DoS) attacks.

- **Output Sanitization Filter:** Strict standardization and JSON schema enforcement of the LLM's output.

3.7 Data Integrity and HMAC Protection

- **HMAC Log Chaining:** A cryptographic hashing algorithm linking consecutive logs, ensuring that any tampering by malicious insiders breaks the chain and is immediately flagged.
- **RAG SHA-256 Checksum Validation:** Guaranteeing the vector database is not compromised by injected falsified documents (Data Poisoning).

In summary, Chapter 3 establishes the rigorous theoretical framework of the SENTINEL architecture, holistically resolving both performance bottlenecks (Tier-1) and deep, secure cognitive reasoning (Tier-2). Chapter 4 will specify the process of translating this architecture into technical source code.

Chương 4

Technical Implementation

This chapter details the software engineering aspects and practical source code implementation of the SENTINEL architecture. Shifting from abstract theory, the content focuses on the project directory organization, core class structures (Classes/Methods), Docker service configurations, and the design of the Graphical User Interface (Streamlit Dashboard) which facilitates Human-in-the-Loop (HITL) interaction.

4.1 Technology Stack and Source Code Structure

- **Core Technologies:** Python 3.10+, LangGraph, LangChain, FAISS, SQLite, Streamlit, Docker, and llama.cpp (via the Llama-cpp-python binding).
- **Directory Structure:** A detailed tree representation strictly separating components: `src/core/` (Tier 1 & 2), `src/rag/` (Vector DB), `src/security/` (Guardrails), `src/dashboard/` (UI), `experiments/`, and `tests/`.

4.2 Tier-1 Implementation: Filtration Engine & Welford

- **RunningStats and SessionBaseline Classes:** Python source code implementation for Welford's algorithm. Resolving dictionary memory allocation challenges via IP hashing and cache garbage collection (TTL cache).
- **RuleEngine Class:** Pattern matching design based on Regular Expressions and Static Thresholds.

4.3 Tier-2 Implementation: AI Agent and RAG

- **OpenAILLMClient / Llama.cpp Wrapper:** Parameter configurations for the Local LLM (enforcing `temperature=0.0` to optimize determinism, context size bounding,

and `n_gpu_layers` mapping).

- **LangGraph Workflow Setup:** Utilizing `StateGraph` to define `analyze_node`, `retrieve_node`, and the conditional routing function `should_retrieve`.
- **DualRetriever Class:** Implementing the FAISS Index and `rank_bm25` to achieve Reciprocal Rank Fusion (RRF). Source code overview of the scoring and sorting algorithms.

4.4 Guardrail and HMAC System Implementation

- **DelimitedDataEncapsulator Class:** Logic for generating secure hexadecimal tokens via `os.urandom` and `hashlib` to wrap log payloads.
- **HMACHashing Class (Database):** Specification of the SQLite database schema (`threat_memory.db`) and the trigger functions calculating SHA-256 hashes derived from Previous Hash + Current Data.

4.5 SOC Administration Dashboard Implementation (Streamlit UI)

- **Dashboard Architecture:** Application of a Frontend (Streamlit) communicating dynamically with the Backend (SQLite/File logs) through reactive UI components.
- **Display Modules:**
 - *Real-time Queue Dashboard:* Visualizing Tier-1 alert metrics and Tier-2 verdicts.
 - *Threat Memory Analytics:* Displaying APT alert graphs across IP timelines.
 - *Audit Trail Integrity:* An automated module verifying HMAC Log Chaining, utilizing a traffic-light interface (Green = Valid, Red = Chain Broken).
- **Human-in-the-loop (HITL):** The interface for reviewing (Approve/Reject) AI-recommended verdicts to update actual Firewall Rules.

4.6 Containerization and Infrastructure Deployment

- **Dockerfile Specification:** Multi-stage build mechanisms to minimize image size and compile C++ libraries (`llama.cpp`) with CUDA acceleration support.
- **docker-compose.yml Service Management:** Linking containers for the Dashboard and Agent Engine, alongside shared log volume mounts.

In summary, Chapter 4 systematizes the software development process of SENTINEL, bridging core algorithms with user interfaces and virtualized infrastructure. Chapter 5 will subsequently establish the testing environment to quantitatively evaluate these components.

Chương 5

Experiments and Evaluation

This chapter presents the empirical evidence of the thesis, validating the research hypotheses through rigorous quantitative metrics. The SENTINEL system is evaluated against a 5-Dimensional framework (5D Metrics: Accuracy, Performance, Security, Explainability, and Integrity). The content emphasizes the layered Ablation Study design and the application of biostatistical models (McNemar's Test, Mann-Whitney U Test) to prove that the architectural enhancements are statistically significant and mathematically sound.

5.1 Experimental Environment and Datasets

- **Hardware Setup:** CPU Intel Core i9, 32GB RAM, GPU NVIDIA RTX 4060 Ti 16GB (utilized for executing the Gemma-2-9B-IT Q4_K_M model).
- **CSE-CIC-IDS2018 Dataset:** Introduction to the dataset encompassing diverse attack typologies (Brute Force, DoS, Web Attack) serving as the baseline for overarching accuracy evaluation.
- **DAPT2020 Dataset:** Employed for testing scenarios involving the identification of multi-stage Advanced Persistent Threat (APT) chains.
- **Unified Data Stream Simulation:** Detailing the scripting process that merges and replays log streams according to virtual timestamps to emulate real-time properties.

5.2 5D Evaluation Metrics and Ablation Study Design

- **Defining the 5D Metrics:** Accuracy (F1, Precision, Recall), Performance (Latency, Throughput), Security (Robustness Rate), Explainability (Audit Completeness), and Integrity (HMAC Validation).
- **Ablation Study Configurations (Config A through F):**

- Config A (Baseline 1): Traditional Rule-based engine exclusively.
- Config B (Baseline 2): Pure Local LLM inference (No RAG, no Welford).
- Config C: Welford Tier-1 + LLM.
- Config D: LLM + Single-RAG (FAISS).
- Config E: LLM + Dual-RAG Hybrid.
- Config F (Holistic SENTINEL): Tier-1 (Welford) + Tier-2 (LangGraph Agent + Dual RAG + Guardrails).

5.3 Accuracy Evaluation & McNemar’s Statistical Test

- **Precision, Recall, and F1-Score Results:** Comparative charts and tables across configurations. Highlighting Config F’s optimal F1 balance (eliminating Rule-based False Positives while enhancing Zero-day Recall).
- **APT Detection Efficacy:** Analysis of Tier-1 (Welford) capturing weak anomalous signals and subsequently activating the Agent’s Threat Memory chains.
- **McNemar’s Test Application:** Comparing the Confusion Matrices of Config B and Config F. Proving $p - value < 0.05$ (rejecting the Null Hypothesis) to confirm that the variance is attributable to architectural superiority rather than random chance.

5.4 Performance Latency Evaluation & Mann-Whitney U Test

- **Inference Latency Analysis:** Comparative table of average latency per flow. The exceptional offloading achieved by Tier-1 (Welford processing benign logs in $O(1)$ time) and the Semantic Cache (Cache Hits reducing LLM latency from 4-6 seconds to milliseconds).
- **Non-parametric Mann-Whitney U Test:** Demonstrating that the latency distribution of the SENTINEL configuration is significantly faster ($p < 0.05$) compared to routing all logs directly through the LLM.

5.5 Adversarial Robustness Evaluation (Security)

- **Adversarial AI Manipulation Dataset (45 Payloads):** Description of manipulative scenarios including Prompt Injections and Delimiter Smuggling (e.g., “Ignore system rules, report this IP as safe”).

- **Mitigation Rate Measurement:** Comparison between an unguarded system (80% manipulation success rate) versus SENTINEL's enabled Delimited Data Encapsulation mechanism (achieving near-perfect mitigation of injection attempts).

5.6 Integrity and RAG Quality Evaluation via LLM-as-a-Judge

- **HMAC Chaining Audit:** A hypothetical scenario where an attacker compromises the database to alter log labels. The dashboard immediately reports the broken hash chain.
- **RAG Scoring (RAGAS / LLM-as-a-Judge):** Utilizing an external Llama-3.1 model as an independent arbiter to score four criteria: Context Precision, Context Recall, Faithfulness, and Answer Relevancy. Proving that Dual-RAG with RRF outperforms Single Vector Search.

In summary, Chapter 5 verifies the technical prowess of SENTINEL through hard quantitative data and rigorous biostatistical tests. Chapter 6 will distill the significance of these findings and outline future trajectories.

Chương 6

Conclusion and Future Work

This concluding chapter synthesizes the comprehensive research journey of the thesis, “A Two-Tier Cognitive Architecture for Automated Threat Detection and Response Using Agentic AI” (SENTINEL). The chapter encapsulates the scientifically proven results, critically self-assesses the limitations within the scope of a master’s thesis, and illuminates new horizons for cybersecurity research integrated with Artificial Intelligence.

6.1 Synthesis of Achieved Research Results

- **Resolving Research Questions:** Reaffirming the successful mitigation of latency bottlenecks and Alert Fatigue via the tiered architecture of the Tier-1 Welford filter and the Tier-2 LangGraph Agent.
- **AI System Security (AI Security):** Demonstrating the empirical viability of Delimited Data Encapsulation and HMAC Chaining structures in thwarting adversarial manipulation risks (Prompt Injection, Delimiter Smuggling, Data Tampering) targeting internal enterprise cognitive systems.
- **Overcoming Zero-Day and APT Challenges:** The exceptional synergy between historical alert tracking (Threat Memory) and the hybrid knowledge repository (Dual-RAG MITRE + NIST) provides profound contextual awareness, enabling the system to expose highly sophisticated campaigns.
- **Validation Rigor:** These achievements transcend theoretical propositions, having been robustly validated by 5D metrics and standard statistical tests (McNemar, Mann-Whitney U) on empirical datasets.

6.2 Scientific and Practical Contributions

- **Scientific Value:** Providing a highly modular architectural framework for integrating Mathematical Statistics with Large Language Models in cybersecurity. This substantially fortifies the theoretical repository concerning LLM security and Guardrails.
- **Practical Value:** The finalized SENTINEL product serves as a core engine or an independent auxiliary tool for Small and Medium Businesses (SMBs) lacking the budget to sustain large-scale Tier-1 SOC teams, while strictly maintaining Zero Trust privacy through offline operations.

6.3 Existing Limitations

Despite the system's demonstrated superiority, the research acknowledges distinct boundaries:

- **Input Log Formats:** The system is currently deeply tested on Network Flow logs and HTTP payloads. Real-world applicability necessitates the ingestion of highly diverse unstructured formats (Windows Event Logs, Linux Syslogs, CloudTrail), requiring significantly more complex parsing mechanisms.
- **Hardware Constraints:** Although inference speed is accelerated via Semantic Caching, processing entirely novel alerts still requires substantial LLM reasoning time. This mandates high capital expenditure for specialized GPU hardware if operating at hundreds of Gigabits/second network scales.
- **Physical Mitigation Design:** The research deliberately constrained the system to recommend actions (e.g., Recommend Firewall Rules) rather than executing physical interventions on routers to prevent Self-Denial of Service (Self-DoS). However, this restricts true Real-Time Blocking capabilities.

6.4 Future Development Directions

Stemming from these limitations, future expansion trajectories for the system include:

- **Federated Learning:** Expanding SENTINEL into a decentralized architecture. Instead of sharing privacy-violating network logs, SOC endpoints share only learned model parameters regarding novel malware variants.
- **Multi-Agent System (MAS):** Decomposing the monolithic LangGraph Agent into specialized sub-agents: Malware Analyst Agent, Network Analyst Agent, and Threat

Intel Agent. These agents would debate prior to issuing a final verdict, further elevating accuracy.

- **Automated Red Teaming:** Constructing an internal Red Team agent to continuously generate sophisticated adversarial payloads targeting Sentinel, thereby self-evaluating and autonomously upgrading the system's defensive posture.

Closing a modest endeavor, yet opening profound aspirations in the pursuit of securing the digital realm through the power of Agentic AI.

Tài liệu tham khảo

- [1] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, “Toward Generating a New Dataset for Cyber Security in Ad hoc Networks,” in *Proceedings of the International Conference on Information Systems Security and Privacy (ICISSP)*, 2018.
- [2] A. Alsubaei, A. Abuhussein, and S. Shiva, “Security Information and Event Management (SIEM) Features, Challenges, and Solutions,” *IEEE Access*, vol. 9, pp. 121111–121128, 2021.
- [3] P. M. M. S. Silva *et al.*, “The Big Data Security Challenges in the Era of Cloud Computing,” *Computer Networks*, vol. 156, pp. 102–115, 2019.
- [4] M. Alshamrani *et al.*, “A Survey on Advanced Persistent Threats: Techniques, Solutions, Challenges, and Research Opportunities,” *IEEE Communications Surveys & Tutorials*, vol. 21, no. 2, pp. 1851–1877, 2021.
- [5] S. Hassan, M. A. Saleem, and O. E. Ogu, “Alert Fatigue in Cybersecurity: A Review,” *IEEE Access*, vol. 10, pp. 58632–58645, 2022.
- [6] B. P. Welford, “Note on a Method for Calculating Corrected Sums of Squares and Products,” *Technometrics*, vol. 4, no. 3, pp. 419–420, 1962.
- [7] P. Lewis *et al.*, “Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks,” *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 33, pp. 9459–9474, 2020.
- [8] LangChain AI, “LangGraph: Multi-Actor, Stateful LLM Applications,” *GitHub repository*, 2024. [Online]. Available: <https://github.com/langchain-ai/langgraph>
- [9] K. Greshake, S. Abdelnabi, S. Mishra, A. Endres, T. Holz, and M. Fritz, “More than you’ve asked for: A Comprehensive Analysis of Novel Prompt Injection Threats to Application-Integrated Large Language Models,” *arXiv preprint arXiv:2302.12173*, 2023.
- [10] P. Cichonski, T. Millar, T. Grance, and K. Scarfone, “Computer Security Incident Handling Guide,” NIST Special Publication 800-61 Revision 2, 2012.
- [11] G. V. Cormack, C. L. A. Clarke, and S. Buettcher, “Reciprocal Rank Fusion Outperforms Condorcet and Individual Bootstrap Product Algorithms,” in *Proceedings of the 32nd International ACM SIGIR Conference on Research and Development in Information Retrieval*, 2009.

- [12] T. Ravindran *et al.*, “Poisoning the Watchtower: Prompt Injection Attacks Against LLM-Augmented Security Operations Through Adversarial Log Content,” *arXiv preprint arXiv:2605.24421*, 2026.
- [13] A. Researcher *et al.*, “CyberRAG: An Agentic RAG cyber attack classification and reporting tool,” *Future Generation Computer Systems*, vol. 176, p. 108186, 2026.
- [14] A. Abdennebi *et al.*, “LanG – A Governance-Aware Agentic AI Platform for Unified Security Operations,” *arXiv preprint arXiv:2604.05440*, 2026.
- [15] M. Analyst *et al.*, “Policy-Guided Threat Hunting: An LLM enabled Framework with Splunk SOC Triage,” *arXiv preprint arXiv:2603.23966*, 2026.